



Факултет по Математика и Информатика
ПУ "Паисий Хилендарски"

SSL, TLS И HTTPS – ЗАЩИТА НА КОМУНИКАЦИЯТА В УЕБ ПРИЛОЖЕНИЯТА

Витали Атиас

Основният проблем: HTTP предава данните в чист текст

HTTP (HyperText Transfer Protocol) е основният протокол, който се използва за комуникация между браузъра и уеб сървъра. Когато потребителят отвори уеб сайт, браузърът изпраща HTTP заявки, а сървърът връща HTTP отговори.

Проблемът е, че стандартният HTTP протокол не криптира данните. Това означава, че информацията се предава в plain text и може да бъде прочетена от всеки, който има достъп до мрежата между клиента и сървъра.

Основният проблем: HTTP предава данните в чист текст

Например, ако потребителят изпрати login заявка чрез HTTP, тази информация може да бъде прихваната от нападател, който наблюдава мрежовия трафик. Това се нарича packet sniffing.

Нападателят може да използва инструмент като **Wireshark**, за да прихване пакети и да види съдържанието им. Ако комуникацията не е криптирана, паролата е видима.

Това създава сериозен риск за сигурността.

Man-in-the-Middle amaka

Една от най-опасните атаки срещу некриптирана комуникация е т.нар. Man-in-the-Middle (MITM) атака. При тази атака нападателят се позиционира между клиента и сървъра. Клиентът вярва, че комуникира със сървъра, а сървърът вярва, че комуникира с клиента. В действителност, нападателят може да чете и дори да променя данните.

Примерен сценарий:

Потребителят се свързва към публична Wi-Fi мрежа (например в кафене).

Решението: криптиране на комуникацията

За да се предотврати прихващането на данни, комуникацията трябва да бъде криптирана.

Криптирането означава, че данните се преобразуват в неразбираема форма, която може да бъде разчетена само от получателя.

Дори ако нападателят прихване encrypted текста, той не може да разбере съдържанието.

Plain text:
`password=mypassword`

Encrypted text:
`XJASD98asd98asda9sd`

SSL – Secure Sockets Layer

SSL (Secure Sockets Layer) е първият широко използван протокол за криптиране на комуникацията между клиент и сървър.

SSL е разработен през 1990-те години от Netscape.

Основната идея на SSL е да създаде сигурен канал между клиента и сървъра.

SSL използва криптография, за да осигури:

- конфиденциалност (данните не могат да бъдат прочетени)
- цялост (данните не могат да бъдат променени)
- автентичност (клиентът знае, че говори със сървъра)

Проблемите със SSL

Въпреки че SSL е бил революционен за времето си, той има сериозни криптографски слабости.

SSL използва по-стари алгоритми, които вече не са сигурни.

Поради тези проблеми, SSL е официално deprecated и не трябва да се използва.

Всички съвременни системи използват TLS вместо SSL.

Важно е да се отбележи, че терминът „SSL“ често се използва разговорно, но реално се използва TLS.

TLS – Transport Layer Security

TLS е наследник на SSL.

TLS е подобрена и по-сигурна версия на SSL.

TLS предоставя същите основни функции:

- криптиране
- защита срещу подслушване
- защита срещу модификация

TLS използва модерни криптографски алгоритми и елиминира слабостите на SSL.

Процесът TLS Handshake (Ръкостискане)

Асиметрично криптиране (Използва се в началото):

- **Цел** - сигурен обмен на "ключове".
- Как работи - сървърът изпраща своя публичен ключ (чрез дигитален сертификат). Клиентът използва този ключ, за да шифрова малко количество информация, която изпраща обратно. Само сървърът може да я дешифрира със своя частен ключ.
- **Защо?** - асиметричното криптиране е много сигурно, но е „тежко“ и бавно за обработка на големи обеми от данни.

Процесът TLS Handshake (Ръкостискане)

Симетрично криптиране (Използва се за самия пренос на данни):

- **Цел** - бързина и ефективност.
- **Как работи** - след като „ръкостискането“ приключи, двете страни вече имат общ, таен сесиен ключ. Всички данни (текст, изображения, пароли), които се обменят след това, се криптират с този общ ключ.
- **Защо** - Симетричното криптиране е изключително бързо и позволява сърфиране в реално време без забавяне.

Защо TLS е по-добър от SSL?

Днес почти целият интернет използва TLS 1.2 или TLS 1.3. SSL 3.0 е официално пенсиониран от 2015 г. поради сериозни уязвимости.

Макар хората често да използват термините като синоними, TLS въвежда критични подобрения:

- **Hashed Message Authentication Code (HMAC)** - по-силна защита срещу промяна на съобщенията по време на път.
- **По-строг протокол за грешки** - TLS прекъсва връзката веднага, ако открие подозрителна активност.
- **Силни алгоритми** - SSL често разчита на по-стари алгоритми като RC4, които днес се считат за лесно пробиваеми.

Сертификати

Сертификатът е цифров документ, който удостоверява идентичността на сървъра.

Сертификатът съдържа:

- домейн (example.com)
- публичен ключ
- информация за издателя
- цифров подпис

Сертификатът е издаден от trusted authority (Certificate Authority).

Пример:

Let's Encrypt е една от най-използваните certificate authorities.

Проверка на сертификата

Браузърът проверява сертификата:

- дали е валиден
- дали е подписан от trusted authority
- дали съвпада с домейна

Ако сертификатът е невалиден, браузърът показва предупреждение

HTTPS – HTTP върху TLS

- **Порт** - Докато стандартният HTTP използва порт 80, HTTPS работи на порт 443.
- **Удостоверяване** - HTTPS не само криптира, но и доказва, че сървърът е този, за който се представя, чрез дигитални сертификати. Така се избягват сайтове-имитатори (Impersonation).
- **Интегритет** - Гарантира, че данните не са променени от трета страна по време на пътя (например хакер в кафенето да не подмени банковата ви сметка в сайта, докато го зареждате).

Какво защитава HTTPS

- **Headers (Хедъри)** - криптират се не само паролите, но и името на браузъра ви, вида на устройството и референтните страници.
- **Query Parameters** - всичко след въпросителния знак в URL (напр. search?query=password) също е защитено.
- **Sniffing Protection** - нападател със софтуер като Wireshark вижда само, че обменяте данни със сървъра, но не и какво точно си казвате.

Какво HTTPS не защитава

- **Application Layer Attacks** - HTTPS е само "бронирован транспорт". Ако в камиона натоварите вирус, той пак ще стигне до получателя.
- **SQL Injection** - Това е атака към базата данни. Нападателят изпраща команда OR 1=1, тя се криптира от HTTPS, сървърът я дешифрира и... базата данни се компрометира.
- **Phishing** - HTTPS сайтът може да е на измамник. Катинарчето означава сигурна връзка, но не винаги означава честен собственик.